

NovaCampus – Security Vulnerability Remediation Report

Project Web Group 1

June 12, 2026

Overview

This report consolidates all security vulnerability fixes applied across the `fix/security-issues`, `fix/security-issues-clean`, and related branches, addressing findings reported by Snyk Open Source and Snyk Code. All changes listed below have been merged into `develop` via pull requests #53, #55, and #71.

1 Dependency Vulnerabilities

CVE / Snyk ID	Component	Issue	Fix
SNYK-JS-UUID-16133035	iam-service, academic-service, billing-service (transitive via <code>sequelize/express-validator</code> → <code>uuid@8.3.2</code>)	Vulnerable <code>uuid</code> version with insecure <code>Math.random()</code> -based fallback	Pinned via <code>npm overrides</code> to <code>uuid@^11.1.1</code> in all three services, which fully resolves the finding (no <code>.snyk</code> policy needed)
Snyk – <code>bcrypt</code> → <code>tar</code>	<code>iam-service</code>	<code>bcrypt@^5.1.1</code> pulled a vulnerable <code>tar</code> (arbitrary file write / DoS via crafted tarball)	Bumped <code>bcrypt</code> to <code>^6.0.0</code>
Snyk – <code>geoip-lite</code> → <code>inflight</code> , <code>ip-address</code>	<code>iam-service</code>	<code>geoip-lite@^1.4.10</code> pulled vulnerable <code>inflight</code> (memory leak) and <code>ip-address</code> (ReDoS)	Bumped <code>geoip-lite</code> to <code>^2.0.2</code>
CVE-2026-41305	All frontend / Next.js workspaces	Next.js vendors <code>postcss@8.4.31</code> , vulnerable to XSS via CSS stringify output	<code>npm overrides</code> forcing <code>postcss >=8.5.10</code> , deduping to patched <code>postcss@8.5.15</code>

2 Code-Level (Snyk Code) Findings

Snyk Rule	Location	Issue	Fix
javascript/Hardcoded Secret (severity 8)	All services (JWT verification)	Hardcoded <code>'defaultSecret'</code> fallback for <code>JWT_SECRET</code>	Removed fallback; services now require <code>JWT_SECRET</code> env var and fail fast at startup if unset
javascript/UseCsrfF orExpress (severity 4)	iam-service, academic-service	No CSRF protection on cookie-authenticated mutating endpoints	Added double-submit CSRF: <code>non-httpOnly XSRF-TOKEN</code> cookie issued on login/refresh, validated against <code>X-CSRF-Token</code> header on mutating requests (bearer-token requests exempted)
javascript/HTTPSourceWithUncheckedType (severity 2, multiple)	academic-service/student.route.js, billing-service/payment.route.js	Unchecked type of <code>req.query.search</code>	express-validator's <code>query('search').optional().isString() + matchedData()</code>
javascript/HTTPSourceWithUncheckedType (severity 2, ×4)	academic-service/teacher.route.js (/courses/stats, /courses/pending-grades, /courses/distribution, /courses/performance)	Unchecked <code>req.query.courseIds</code> passed to <code>.split(',')</code>	Added <code>typeof courseIds !== 'string'</code> guard before <code>.split()</code> on all 4 endpoints
javascript/XSS (unsanitized <code>req.params.id</code> reaching <code>res.write</code> via SSE hub)	iam-service/auth.controller.js (<code>revokeSession</code>)	<code>req.params.id</code> used unvalidated in a session-revoke flow whose result is broadcast over SSE	Validate <code>req.params.id</code> against a UUID regex before use; reject with 400 if invalid
javascript/HTTPSourceWithUncheckedType	iam-service/auth.controller.js (<code>changePassword</code>)	<code>req.body.newPassword.length</code> accessed without checking type	<code>typeof</code> checks on <code>currentPassword/newPassword</code> before length validation
Information disclosure	All Express services	X-Powered-By header exposed Express framework	Disabled via <code>app.disable('x-powered-by')</code>
Insecure crypto (dead-code taint)	<code>auth.service.js</code> / JWT handling	Unused <code>decodeToken</code> helper decoded JWTs without verifying signature	Removed dead code
Insecure hashing	seed script	<code>sha1/md5</code> used for demo session tokens and offline embedding hashes	Replaced with <code>sha256</code>
Cookie attribute static analysis	iam-service/auth.controller.js	<code>res.cookie</code> options built via a shared helper function (not statically verifiable by Snyk)	Inlined <code>httpOnly/secure/sameSite</code> attributes at each <code>res.cookie()</code> call site

3 Summary

- **18 distinct findings** addressed across `iam-service`, `academic-service`, `billing-service`, and the frontend (Next.js / postcss).
- All changes are merged into `develop` via pull requests **#53**, **#55**, and **#71**.